Análisis normativo de la arquitectura de IA

Caso práctico: asistente para clasificar y derivar avisos ciudadanos

Ayuntamiento de Madrid

Documento de trabajo en formato de tablas `longtable`, A4 apaisado. Cada marco se analiza por separado y se traduce a decisiones de arquitectura, operación y evidencia para el piloto hipotético descrito en el caso práctico.

Octubre de 2026

Alcance y criterio de lectura

El caso plantea un sistema que recibe avisos, minimiza o enmascara datos, propone categoría, resumen y unidad de destino, y deja la aceptación, corrección o rechazo a personal municipal. No resuelve expedientes, no determina derechos ni comunica decisiones administrativas de forma autónoma. La arquitectura analizada es la propuesta conceptual del caso; no se afirma que sea un sistema implantado por el Ayuntamiento.

Las tablas son una traducción práctica, no un dictamen jurídico, una declaración de conformidad ni una certificación ISO. La calificación depende del uso previsto y real, del catálogo de destinos, de la integración con servicios y de los efectos sobre las personas. Las ediciones completas de las normas ISO deben consultarse para validar requisitos y epígrafes antes de una implantación.

1. Reglamento (UE) 2024/1689 — AI Act

Evaluación basada en finalidad y contexto de uso; el Reglamento ha de leerse junto con sus modificaciones vigentes.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Finalidad prevista y rol (arts. 3 y 6)	Asistente interno de triaje: clasifica texto y sugiere destino; el empleado decide. La calificación no deriva del uso de IA por sí solo.	Fijar en ficha de sistema los usos permitidos, usuarios, entradas, salidas, límites y prohibiciones. Mantener separación entre sugerencia y decisión/registro definitivo.	Inventario del sistema, instrucción de uso y aprobación de negocio, asesoría jurídica y gobernanza IA. Repetir análisis si cambia la finalidad o la integración.
Anexo III, punto 5(a) y (d); art. 6	El punto 5(a) cubre ciertos usos para evaluar elegibilidad o conceder/reducir/revocar beneficios y servicios públicos esenciales; 5(d) contempla clasificar llamadas de emergencia y despachar o priorizar primera respuesta. El mero enrutamiento de avisos ordinarios no permite concluir automáticamente que aplique o no aplique.	El catálogo debe distinguir avisos rutinarios de solicitudes de acceso a servicios esenciales y de emergencias. No usar esta herramienta para determinar elegibilidad ni priorizar despacho de emergencias.	Dictamen de clasificación documentado, con mapa de procesos/destinos y análisis del Anexo III. Si el propósito queda dentro de una categoría, comprobar excepciones del art. 6(3) y sus condiciones sin presumir que excluyen el sistema.
Sistema de alto riesgo: proveedor (arts. 8–15)	Solo si la clasificación concluye alto riesgo, se activan requisitos aplicables al proveedor, incluidos gestión de riesgos, datos, documentación, registros, transparencia, supervisión humana, precisión/robustez/ciberseguridad y evaluación de conformidad.	Exigir al proveedor trazabilidad de modelo/datos, controles de calidad, registro de eventos, umbrales, documentación y mecanismo de cambios. La interfaz debe permitir comprensión, intervención y anulación de cada sugerencia.	Matriz de aplicabilidad por rol contractual; documentación técnica y pruebas del proveedor; registro de versiones; evidencias de supervisión y evaluación.
Desplegador público (art. 26)	Si es alto riesgo, el Ayuntamiento como desplegador debe usar el sistema según instrucciones, asignar supervisión competente, vigilar funcionamiento, conservar registros bajo su control y atender obligaciones de información que correspondan.	Autenticación individual, permisos por rol, cola de revisión y botón visible de corregir/rechazar/escalar; logs con propuesta, versión, usuario, decisión y fecha. Procedimiento para incidentes y parada.	Procedimiento operativo, formación, logs verificables, SLA y reglas de escalado/parada. Confirmar obligaciones exactas según rol de la entidad y versión vigente.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Evaluación de impacto en derechos fundamentales (art. 27)	Antes del primer uso, determinados organismos públicos que despliegan un sistema de alto riesgo deben realizar FRIA, con alcance y excepciones del propio artículo. No es equivalente a la EIPD del RGPD.	Evaluar los efectos del flujo completo y las poblaciones afectadas, incluido el error de derivación, el escalado y la accesibilidad; enlazar mitigaciones con decisiones de diseño.	Determinar formalmente si el art. 27 aplica; conservar evaluación, medidas, responsable y actualización por cambios relevantes. Coordinarla con la evaluación de impacto ISO/IEC 42005, sin tratarlas como intercambiables.
Alfabetización en IA (art. 4)	Proveedores y desplegadores deben adoptar medidas para un nivel suficiente de alfabetización en IA del personal y otras personas que operan/usan el sistema.	Formación diferenciada para revisores, administradores y responsables: capacidades, límites, errores, sesgos y manejo de datos.	Plan de formación, materiales, fecha, perfil y registro de participación.
Transparencia ante interacción directa (art. 50)	La obligación de informar de que se interactúa con IA es pertinente si el sistema interactúa directamente con personas físicas. En el diseño descrito, el usuario de la interfaz es personal municipal; no se presupone interacción ciudadana directa.	Mantener la IA como apoyo interno. Si se añade chatbot o canal ciudadano, revisar la obligación de transparencia y el diseño de avisos antes de activarlo.	Diagrama de canales y usuarios, textos informativos aplicables y revisión de cambios de interfaz.

Punto de control: detener la puesta en marcha hasta documentar la clasificación. El análisis debe actualizarse ante cambios de finalidad, destinos, automatización o efectos sobre derechos y servicios esenciales.

2. Reglamento (UE) 2016/679 - RGPD

Protección de datos personales desde el diseño de entrada, inferencia, revisión, integración, conservación y contratación.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Principios y responsabilidad (arts. 5 y 24)	Los avisos pueden contener identificadores, domicilios, salud u otros datos. La seudonimización no los convierte automáticamente en anónimos.	Minimizar el texto antes de enviarlo al modelo; limitar finalidad a triaje; mantener exactitud y plazos; atribuir roles y responsabilidades para cada etapa.	Registro de actividades, inventario de datos, flujo y finalidades, retención por tipo de dato y prueba de eliminación/enmascaramiento.
Licitud y categorías especiales (arts. 6 y 9)	Identificar base del art. 6 para cada finalidad. Si aparecen datos de categorías especiales, verificar si existe una excepción válida del art. 9; la mera presencia incidental no habilita su tratamiento.	Diseñar detección/redacción antes del servicio de IA y ruta de revisión restringida para casos que no puedan excluirse. No inferir atributos sensibles.	Análisis jurídico de base y condición del art. 9 cuando proceda; inventario de categorías, controles de acceso y prueba de la canalización de minimización.
Información y transparencia (arts. 12–14)	La persona debe recibir información exigible sobre tratamiento, finalidades, base, destinatarios, conservación y derechos. La aplicación concreta depende de la recogida y del canal.	Integrar aviso de privacidad en el canal de recepción y coordinarlo con mensajes y contratación de proveedores. No confundir transparencia RGPD con transparencia AI Act.	Información publicada por canal, versiones, responsable y procedimiento de actualización.
Privacidad desde el diseño y por defecto (art. 25)	Minimización, seudonimización y configuración protectora desde el diseño y por defecto.	Procesar solo campos necesarios; segregación de entornos; evitar que entradas o salidas se reutilicen para entrenamiento; restringir acceso a texto original; separar contenido y métricas.	Diagrama de arquitectura, configuración por defecto, pruebas de minimización y decisión expresa sobre reutilización.
Encargados y proveedores (art. 28)	Si un proveedor trata datos por cuenta del Ayuntamiento, se requiere contrato con instrucciones, confidencialidad, seguridad, subencargados, asistencia y supresión/devolución.	Pasarela de IA con proveedor autorizado; impedir almacenamiento/entrenamiento no pactados; definir ubicación, transferencias internacionales y subencargados.	Contrato de encargo, lista de subencargados, ubicación/transferencias, retención, borrado, auditoría y gestión de cambios.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Seguridad (art. 32)	Medidas técnicas y organizativas apropiadas al riesgo.	Cifrado en tránsito y almacenamiento, mínimo privilegio, autenticación robusta, segregación, secretos, copias, monitorización, pruebas y respuesta a incidentes.	Modelo de amenazas, controles implantados, evidencias de pruebas, registro de accesos y plan de incidentes.
Evaluación de impacto (art. 35)	EIPD antes del tratamiento cuando sea probable un alto riesgo para derechos y libertades; comprobar criterios y listas/guías aplicables.	Evaluar efectos del tratamiento sobre personas, no solo exactitud del modelo; considerar escala, datos sensibles, vulnerabilidad, combinación de fuentes y consecuencias de una derivación incorrecta.	Cribado EIPD y, si procede, informe, consulta al DPD y plan de medidas. Distinguirla de la FRIA del AI Act y de ISO/IEC 42005.
Decisiones automatizadas (art. 22)	La propuesta no pretende producir por sí sola efectos jurídicos ni afectar significativamente a una persona. Si la operación real pasa a decidir automáticamente, valorar el art. 22 y sus salvaguardas/excepciones.	Hacer que la validación humana sea real: acceso a contexto suficiente, capacidad efectiva de modificar y prohibición de derivación automática en casos de impacto.	Pruebas de flujo que acrediten revisión antes de registrar/derivar; logs de decisión; evaluación jurídica ante automatización o consecuencias relevantes.
Conservación y ejercicio de derechos (arts. 15–21)	Los registros del sistema pueden contener datos personales y no deben conservarse indefinidamente por ser “logs”.	Política de retención diferenciada entre aviso, texto, sugerencia, corrección y auditoría; mecanismo de búsqueda y supresión/limitación cuando proceda.	Calendario de conservación y borrado, responsables, controles de acceso y procedimientos para derechos.

3. ISO/IEC 42001:2023 - Sistema de gestión de IA

Norma de sistema de gestión. Los epígrafes indican dónde estructurar gobierno, evaluación, operación y mejora del piloto.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Cl. 4.1–4.4: contexto, partes interesadas, alcance y sistema de gestión	Incluir servicio municipal, personal revisor, ciudadanía afectada, unidades destino, proveedor, entorno jurídico y límites del piloto.	Definir el sistema dentro del ámbito de gestión: canal de entrada, servicio IA, catálogo, interfaz humana, integración y auditoría.	Alcance aprobado; necesidades/expectativas pertinentes; dependencias y exclusiones justificadas.
Cl. 5.1–5.3: liderazgo, política, roles y responsabilidades	Asignar quién patrocina, opera, mantiene catálogo, valida, supervisa privacidad/seguridad y acepta riesgo residual.	Separar responsabilidades de proveedor, dueño del servicio, DPD, asesoría jurídica, seguridad, gobernanza IA y revisor.	Política de IA y matriz RACI/nombramientos; autoridad para bloquear o pausar el sistema.
Cl. 6.1.1–6.1.3: riesgos y oportunidades; evaluación y tratamiento de riesgos de IA	Convertir R1–R8 del caso (error, exposición, sesgo, resumen incorrecto, accesibilidad, reutilización, ciberseguridad y clasificación legal) en riesgos gestionados.	Mantener registro vivo con criterios, propietario, probabilidad/impacto, tratamiento, riesgo residual y revisión por cambio/incidente.	Método y criterios, evaluación aprobada, plan de tratamiento, aceptación de riesgos y declaración de aplicabilidad de controles pertinentes.
Cl. 6.1.4 y 8.4: evaluación de impacto del sistema de IA	Analizar impactos previsibles del sistema sobre personas y colectivos a través del aviso, la clasificación y la derivación.	Vincular resultados con requisitos de la interfaz, umbrales, escalado, canales alternativos, minimización y supervisión.	Evaluación documentada, medidas, responsables y actualización durante el ciclo de vida; coordinación con FRIA/EIPD cuando aplique.
Cl. 6.2: objetivos de IA y planificación	Los objetivos del caso incluyen reducir tiempo sin empeorar calidad, evitar errores críticos y mejorar trazabilidad y privacidad.	Definir métricas, umbrales y responsables antes de probar; no fijar el éxito después de ver resultados.	Objetivos medibles, línea base, tolerancias, fuente de datos, cadencia e indicadores de parada.
Cl. 7.2–7.5: competencia, concienciación, comunicación e información documentada	Personal capaz de interpretar sugerencias, confianza, incertidumbre, datos sensibles y vías de escalado.	Control documental para requisitos, conjunto de categorías, modelo, pruebas, cambios, registros y formación.	Competencias/formación; plan de comunicación; control de versiones, acceso, conservación y disponibilidad documental.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Cl. 8.1–8.3: planificación y control operacional; evaluación y tratamiento de riesgos	Ejecutar el flujo aprobado y aplicar tratamientos definidos durante desarrollo, prueba, compra y uso.	Puertas de aprobación: datos sintéticos; muestra minimizada autorizada; validación offline; piloto controlado; revisión humana antes de integración.	Criterios operativos, registros de ejecución, cambios autorizados, criterios de aceptación y seguimiento de tratamientos.
Anexo A.10: relaciones con terceros	El proveedor puede alojar el modelo o procesar texto ciudadano; la dependencia contractual y técnica afecta el riesgo.	Gestionar cambios de modelo/API, subencargados, ubicación, reutilización, portabilidad, borrado, continuidad y notificación.	Evaluación de proveedor, requisitos contractuales, SLA, pruebas de salida y procedimiento de cambio.
Cl. 9.1–9.3: seguimiento, auditoría interna y revisión por dirección	Comprobar calidad por categoría, tasa de corrección/escalado, errores críticos, privacidad, latencia y carga del personal.	Panel y revisión periódica; auditar permisos, trazabilidad, comportamiento y cumplimiento de criterios de salida.	Resultados reproducibles, auditorías, actas de revisión, decisiones correctivas y responsables.
Cl. 10.1–10.2: mejora continua y no conformidad/acción correctiva	Desviaciones, incidentes, sesgos o cambios deben producir corrección y, si procede, pausa.	Canal de incidentes y bucle para ajustar catálogo, datos, modelo, formación o proceso; volver a evaluar antes de reanudar.	Registro de no conformidades, causa raíz, acción, verificación de eficacia y decisión de reanudación.
Anexo A: controles de referencia (A.2–A.10)	Considerar políticas (A.2), organización interna (A.3), recursos (A.4), evaluación de impacto (A.5), ciclo de vida (A.6), datos (A.7), información a interesados (A.8), uso (A.9) y terceros (A.10).	Seleccionar controles según evaluación y alcance; la presencia en el Anexo A no significa que todos sean aplicables automáticamente.	Declaración de aplicabilidad y justificación de inclusión/exclusión; evidencias conforme a la norma completa y Anexo B de orientación.

4. ISO/IEC 23894:2023 - Gestión de riesgos de IA

Guía para integrar la gestión de riesgos relacionados con IA en el contexto y procesos de la organización.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Cl. 5: marco de gestión de riesgos	Integrar riesgo de IA en gobernanza y gestión municipal; el riesgo depende del contexto y puede cambiar durante el ciclo de vida.	Establecer liderazgo, integración, diseño, implementación, evaluación y mejora del marco para el piloto y sus proveedores.	Marco aprobado, responsables, recursos, integración con riesgos corporativos y revisión periódica.
Cl. 5.4.1: comprender organización y contexto	Contexto de canal municipal, idiomas, tipología de incidencias, unidades receptoras, población afectada y entorno legal/contractual.	Definir contexto de uso, propósito, límites, dependencias, tolerancia al error y eventos externos.	Análisis contextual y supuestos que sustentan el alcance.
Cl. 6.2–6.3: comunicación/consulta y alcance, contexto y criterios	Involucrar a revisores, unidades de destino, privacidad, seguridad y grupos afectados en la identificación y aceptación de riesgos.	Determinar criterios para clasificación errónea, exposición, sesgo, accesibilidad y escalado; habilitar comunicación de incidencias.	Plan de consulta, criterios de riesgo y actas de validación.
Cl. 6.4.2: identificación del riesgo	Riesgos del caso: categoría/destino equivocados, fuga o reutilización de datos, resumen falso, sesgo territorial/lingüístico, inaccesibilidad, ciberataque y deriva de finalidad.	Mapear fuentes, eventos, consecuencias, grupos afectados, activos y controles existentes por etapa del flujo.	Registro de riesgos con causa, evento, consecuencia, titular y trazabilidad a componente/proceso.
Cl. 6.4.3: análisis del riesgo	Estimar consecuencias y probabilidad; atender incertidumbre, límites de datos y fallos por categorías minoritarias.	Combinar métricas offline, pruebas con escenarios adversos y criterio experto. No presentar estimaciones ilustrativas del caso como mediciones reales.	Método y evidencia de análisis; desagregación de rendimiento por categoría y registro de incertidumbres.
Cl. 6.4.4: evaluación del riesgo	Comparar riesgos analizados con criterios y decidir aceptación, tratamiento o escalado.	Definir cuándo la confianza baja, la entrada es ambigua, urgente o sensible y debe pasar a persona sin recomendación automática.	Decisión documentada por responsable autorizado; criterios de parada y aceptación de riesgo residual.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Cl. 6.5: tratamiento del riesgo	Elegir evitar, modificar, compartir o retener el riesgo, según contexto y criterio municipal.	Traducir medidas a controles: minimización, filtros, validación humana, restricciones del catálogo, umbral, ciberseguridad, alternativa manual y pruebas.	Plan de tratamiento con acciones, recursos, responsable, plazo y riesgo residual.
Cl. 6.6–6.7: seguimiento/revisión y registro/informe	El modelo, el catálogo y los patrones de entrada pueden cambiar y alterar los riesgos.	Revisar por calendario y ante versión nueva, cambio de proveedor, incidente, nueva categoría o aumento de automatización.	Registro de decisiones y eventos, métricas periódicas, historial de versiones e informes.

5. ISO/IEC 42005:2025 - Evaluación de impacto de sistemas de IA

Guía para evaluar impactos previstos y previsibles sobre individuos, grupos y sociedad durante el ciclo de vida.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Cl. 5.1–5.3: proceso, documentación e integración	Establecer un proceso consistente para este sistema y conectarlo con gestión de riesgos, privacidad, seguridad, adquisiciones y aprobación del piloto.	Usar la evaluación como actividad iterativa, no como formulario único; alimentar con ella los tratamientos de riesgo y los requisitos de diseño.	Procedimiento aprobado, responsables y relación explícita con ISO/IEC 42001 cl. 6.1.4/8.4, EIPD y FRIA.
Cl. 5.4: cuándo evaluar	Evaluar antes del uso y revisar cuando cambien propósito, contexto, datos, modelo, proveedor, población o efectos previsibles.	Incorporar disparadores de reevaluación a la gestión de versiones y cambios.	Calendario y eventos disparadores; historial de evaluaciones.
Cl. 5.5–5.7: alcance, responsabilidad y umbrales	Delimitar aviso, resumen, categoría, unidad de destino, personas/grupos expuestos y usos prohibidos. Determinar quién evalúa y cómo se clasifican usos sensibles/restringidos.	Incluir usuarios internos y ciudadanía afectada; fijar criterios de materialidad y escalado de impactos, sin inventar umbrales de riesgo.	Alcance, equipo competente, consultas, criterios y aprobación de umbrales.
Cl. 5.8–5.11: realizar, analizar, registrar y aprobar evaluación	Evaluar impactos intencionados y no intencionados: retraso o pérdida de aviso, acceso desigual, exposición de datos, estigmatización o confianza excesiva en la recomendación.	Analizar por etapas y grupos; diseñar mitigación, alternativa manual, revisión y mecanismo de reclamación/retroalimentación.	Matriz de impacto, evidencia, límites, medidas, riesgo residual y decisión aprobatoria.
Cl. 5.12: monitorización y revisión	Los impactos pueden aparecer después del despliegue por cambios de uso, datos o población.	Revisar indicadores de equidad, errores críticos, correcciones humanas, quejas e incidentes y activar reevaluación.	Responsable y frecuencia/eventos de revisión; decisiones y cambios documentados.
Cl. 6.2–6.6: contenido de la evaluación — alcance, sistema, datos, algoritmos/modelos y entorno	Describir arquitectura del caso: datos de entrada, redacción, servicio de IA, catálogo, interfaz de revisión, integración y auditoría.	Documentar propósito, límites, modelo/proveedor, datos, condiciones de despliegue, controles y dependencias.	Ficha técnica, diagrama de flujo, inventario de datos y versiones, entorno y supuestos.

Elemento / referencia	Aplicación al caso	Implicación para arquitectura y operación	Evidencia / decisión requerida
Cl. 6.7–6.9: partes interesadas, impactos y medidas	Incorporar unidades municipales, revisores, residentes y colectivos cuyas comunicaciones puedan ser tratadas de forma desigual.	Relacionar cada impacto con población, mecanismo, severidad, probabilidad, salvaguarda, indicador y propietario.	Registro de partes interesadas, análisis de impactos y plan de medidas verificables.

Secuencia de aplicación recomendada

1. Aprobar propósito, límites, roles y mapa de flujo; separar expresamente triaje ordinario de elegibilidad de servicios y despacho de emergencias.
2. Completar clasificación AI Act y cribado RGPD; decidir si son exigibles evaluación de alto riesgo, FRIA y EIPD.
3. Establecer el alcance del sistema de gestión (ISO/IEC 42001), registro y criterios de riesgos (ISO/IEC 23894) y proceso/informe de impactos (ISO/IEC 42005).
4. Construir con datos sintéticos; probar minimización, supervisión, trazabilidad, errores y rutas de escalado antes de cualquier dato real autorizado.
5. Fijar umbrales de salida antes del piloto, documentar la aprobación multidisciplinar y reevaluar ante cambios o incidentes.

Fuentes y notas de versión

- Caso base: *Caso práctico de aplicación de inteligencia artificial — Ayuntamiento de Madrid*, documento aportado por el usuario, especialmente secciones 2–8 y apéndice B.
- AI Act: Reglamento (UE) 2024/1689, texto en EUR-Lex: `https://eur-lex.europa.eu/eli/reg/2024/1689/oj`. Modificación consultada: Reglamento (UE) 2026/1744, `https://eur-lex.europa.eu/eli/reg/2026/1744/oj`. Comprobar texto consolidado, fechas de aplicación y modificaciones posteriores al iniciar el piloto.
- RGPD: Reglamento (UE) 2016/679, EUR-Lex: `https://eur-lex.europa.eu/eli/reg/2016/679/oj`.
- ISO/IEC 42001:2023, ficha oficial ISO: `https://www.iso.org/standard/81230.html`.
- ISO/IEC 23894:2023, ficha oficial ISO: `https://www.iso.org/standard/77304.html`.
- ISO/IEC 42005:2025, ficha oficial ISO: `https://www.iso.org/standard/42005.html`.

Las normas ISO son documentos protegidos por derechos de autor. Esta síntesis no reproduce su texto y ofrece referencias temáticas para localizar los epígrafes en las ediciones oficiales. Verificar la numeración contra la copia licenciada aplicable antes de emplearla como matriz formal de auditoría.